

IT AUDIT PROJECT: “Cybersecurity & Data Privacy Compliance Audit”

Task 1: Risk Identification

Risk Assessment Matrix

Likelihood (L)	Impact (I)	Risk Score (R) R = L × I
1 = Very Unlikely	1 = Negligible	
2 = Unlikely	2 = Minor	1–5 = Low
3 = Possible	3 = Moderate	6–12 = Medium
4 = Likely	4 = Significant	13–19 = High
5 = Very Likely	5 = Severe	20-25 = Very High

Type	Risk	L	I	Risk Score	Rating
Cybersecurity	Weak password controls	4	4	16	High
Cybersecurity	Manual offboarding process	4	4	16	High
Cybersecurity	Backup failure with no follow-up investigation	3	5	15	High
Cybersecurity	Disaster recovery not tested since Apr 2023	4	5	20	Very High

IT AUDIT PROJECT: "Cybersecurity & Data Privacy Compliance Audit"

Cybersecurity	Short network log retention (90 days)	3	3	9	Medium
Data Privacy	Over-retention of personal data (kept 10 years instead of 5)	5	5	25	Very High
Data Privacy	Weak email encryption (recommended but not enforced)	4	5	20	Very High
Data Privacy	Manual offboarding process	5	4	20	Very High
Data Privacy	Outdated Data Sharing Agreement	3	3	9	Medium
Data Privacy	Lack of documented drive disposal evidence	2	4	8	Medium
Data Privacy	Incomplete breach-notification readiness	3	4	12	Medium

Task 2: Control Mapping

Control Inventory Table

Control	Control Type
---------	--------------

IT AUDIT PROJECT: “Cybersecurity & Data Privacy Compliance Audit”

Minimum password requirements	Preventive
Passwords expire every 90 days	Preventive
Admin privileges limited to IT Security team	Preventive
Accounts deactivated within 48 hours after HR notification	Preventive
Resigned employees marked as inactive	Detective
Firewall set to block all by default	Preventive
VPN required for remote access	Preventive
Network logs retained	Detective
Daily scheduled backups	Preventive
Backup success and failure logged	Detective
Recovery testing performed every 6 months	Corrective
Escalation to DPO or COO for severe incidents	Corrective
Actions taken for phishing attempts (e.g., block sender, reset password)	Corrective
Privacy notices and consent requirements enforced	Preventive
Data retention limits applied	Preventive
Retention logs track expired records	Detective
Email encryption recommended	Preventive
Hard drives properly destroyed when decommissioned	Preventive

IT AUDIT PROJECT: “Cybersecurity & Data Privacy Compliance Audit”

Breach notification completed within 72 hours	Corrective
HR-to-IT notification workflow for employee exits	Preventive
Manual offboarding process	Preventive

Task 3: Evidence Gathering Plan

Evidence Gathering Worksheet

Audit Area	Type of Evidence	Evidence-Gathering Technique
User access management	Access list, password policy, HR–IT policy	Inspection, Inquiry
Password policy enforcement	Password policy, system configuration screenshots, password reset logs	Inspection, Reperformance
Backups and disaster recovery	Backup logs, recovery test reports, backup configuration	Inspection, Reperformance
Data storage and encryption	System configuration, encryption settings, data handling policy	Inspection, Observation
Retention and practices	Retention logs, retention policy	Inspection
Data breach procedures	Incident response policy, incident report logs	Inspection, Inquiry, Reperformance

Task 4: Control Testing

Control Testing Procedures

IT AUDIT PROJECT: "Cybersecurity & Data Privacy Compliance Audit"

Control	Design Effectiveness	Operational Effectiveness Testing Procedure	Expected Evidence
Password minimum requirements and 90-day expiry	Lacks full complexity requirements and could add Multi-factor authentication	1. Attempt to set weak passwords such as "1234567a" or "aaaaaa1" 2. Review system configuration (check code) 3. Check password age 4. interview IT admin.	Password configuration screenshots; user password age report; system logs; interview notes.
Firewall Block-All-By-Default rule	Good preventive control limiting unauthorized traffic.	1. Review firewall rule table 2. Test unauthorized connection 3. Observe the firewall console.	Firewall rule export; blocked traffic logs; configuration screenshots.
Daily scheduled backups	Appropriate design for HR and payroll system but needs proper monitoring.	1. Review past weeks backup logs 2. Verify if conducted failure procedures	Backup logs; restoration test results; timestamps verifying daily execution.

IT AUDIT PROJECT: "Cybersecurity & Data Privacy Compliance Audit"

		3. Perform sample file restoration.	
HR-IT Exit notification & Account deactivation	Relies on manual steps which are prone to human error.	1. Match HR exit emails to access list 2. Sample test terminated accounts 3. interview IT staff.	HR exit emails; access list showing inactive accounts; sample deactivation test results; interview notes.
Data Retention (5-Year Limit)	There's no automated process to remove or manage records once they pass the retention period, so expired records might stay in the system longer than intended.	1. Check the retention logs for records marked as EXPIRED. 2. Confirm whether any of these EXPIRED records are still in the system. 3. Talk to the relevant staff (IT or Data Protection team) to understand how expired records are actually handled.	Retention log entries; deletion records; interview documentation.

IT AUDIT PROJECT: "Cybersecurity & Data Privacy Compliance Audit"

Task 5: Audit Findings

Audit Findings Report

Finding	Condition	Criteria	Cause	Effect	Recommendation
1. Password Controls weak and not fully enforced	Password policy lacks complexity, MFA is not implemented. Reuse restriction is also not mentioned.	Strong authentication should include complexity requirements, reuse limits, and multi-factor authentication.	Outdated and weak policy.	Weak passwords make it easier for unauthorized users to break into the system.	• Update password policy • Enforce complexity • Enable Multi-factor authentication • Implement password reuse restrictions.
2. Firewall Block-all configuration not fully validated	Firewall rules are documented but no periodic validation to test if actually operationally accurate and secured.	Network security controls require periodic review and validation of firewall rules.	No formal firewall rule review or test schedule in place.	Potential for unauthorized traffic if rules are outdated or have code errors.	• Implement periodic firewall rule reviews • Conduct documented test attempts.

IT AUDIT PROJECT: "Cybersecurity & Data Privacy Compliance Audit"

3. Backup Process Not Fully Reliable	A backup recently failed, but no investigation was done. Recovery testing also hasn't been performed since April 2023.	Backup and recovery controls require ongoing monitoring and regular test restorations.	Backups are not consistently reviewed, failures aren't analyzed, and no schedule exists for recovery testing.	Possible data loss and inability to recover systems during an incident affecting business continuity.	• Perform daily backup reviews • Investigate failures • Implement recovery testing regularly.
4. Manual offboarding control error-prone	IT relies on HR's email notifications and manually disables accounts. There's no automated link between systems.	Access should be removed immediately when an employee leaves.	The entire workflow depends on manual steps and isn't supported by automation.	Accounts may stay active longer than intended, increasing the risk of unauthorized access.	• Connect the HR system with access management • Automate account deactivation • Perform periodic access reviews.
5. Retention Policy not effectively executed	Records that should already be removed are still stored, and there's no proof of deletion for items past	Retention standards require that records be removed once they reach the end of their retention period.	There's no automated deletion system, and monitoring around record cleanup is weak.	Keeping unnecessary personal data increases privacy risks and leads to non-compliance.	• Add an automated deletion process • Set clear documentation procedures of record

IT AUDIT PROJECT: “Cybersecurity & Data Privacy Compliance Audit”

	the 5-year mark.				removals
--	------------------	--	--	--	----------

Task 6: Final Audit Report

1. Executive Summary

The main target of this IT Audit report is to assess the Cybersecurity and Data Privacy controls of NagaTech Solutions, Inc.. It is important to conduct this audit since the company handles 300 employees and their sensitive data. The goal is to check how well cybersecurity and data privacy controls are working, identify risks, and check if the company follows data protection policies.

NagaTech has several important controls implemented such as password policies, network protections, backups, and retention policies. Some areas need updates. The password policies are weak, backups are not fully reliable, retention policies are unfollowed and much more. These gaps could make it easier for unauthorized access, data loss, or privacy incidents especially considering the company’s recent phishing attack.

The company should take steps to improve their controls. For example, improving password rules, automating offboarding and data retention, enforcing email encryption, and testing backups regularly will help protect sensitive information and reduce risks. All in all, the audit shows that NagaTech faces moderate to high risks. Immediate action is needed to fix the weaknesses identified and make the company’s systems more secure. implemented.

2. Audit Methodology

The audit used standard IT audit techniques, mainly Inspection, Inquiry, Observation, Reperformance, and Risk Assessment. Inspection is used to review logs, policies, and current available documents to understand the design controls. Inquiry is used to clarify how these design controls operate in practice. Observation is used to verify if operational controls work based on the policies and inquiries gathered. Reperformance is done to test systems such as the password rules, backup checks, and HR-IT processes. The risk assessment is used to determine the risk level of the findings and its possible effect on the company’s operations

3. Audit Scope and Limitations

Scope

The audit covered the following areas:

- User access and account management
- Password and authentication controls

IT AUDIT PROJECT: “Cybersecurity & Data Privacy Compliance Audit”

- Firewall, VPN, and general network security
- Backup routines and disaster recovery processes
- Data privacy practices, including retention and breach procedures
- Email transmission safeguards
- Incident response handling
- Coordination between HR and IT during access changes

Limitations

The assessment was limited to the evidence provided. Specifically:

- Policy Reference
- Access List
- Backup Log
- HR exit email
- Incident report
- Retention log

4. Findings & Recommendations

The cybersecurity and data privacy audit of NagaTech Solutions, Inc. showed that the company does have several basic controls implemented. Though many of these controls are weak or are not actively followed. These policies require better support and monitoring. The mispractice of policies will create gaps that could lead to potential breach and exploits.

The audit recommends strengthening technical controls, automating critical processes like offboarding and data deletion, and ensuring regular reviews of policies, backups, and encryption practices. Improving documentation and enforcing mandatory checks will help the organization create a more secured and accountable company.

5. Risk rating summary

The Audit shows a High to Very High risk rating. This finding highlights the weak and outdated policies that need to be updated. The most serious concerns include weak password practices, untested disaster recovery procedures, unreliable backup monitoring, and over-retention of personal data. These policies and practices are very harmful to the company and could lead to loss in business resources such as data, reputation and revenue. Since the audit is focused on cybersecurity and privacy, it shows the vulnerability of the current systems.

IT AUDIT PROJECT: “Cybersecurity & Data Privacy Compliance Audit”

The medium level risk, though less urgent, still can contribute to long-term vulnerability. Short network log retention, outdated data sharing agreements, incomplete breach-notification procedures, and missing documentation for drive disposal. These risks limit the organization’s ability to investigate incidents, coordinate with external partners, or prove compliance when needed. Addressing both the high-risk and medium-risk areas will help the company prevent data loss, reduce operational disruptions, and strengthen its overall cybersecurity and privacy compliance.

6. Conclusion

The IT audit of NagaTech Solutions, Inc. showed that the existing controls of the company are either weak and outdated, or are not strictly followed operationally. The policies need huge revisions in most areas to address gaps and ensure that the business is secure and performing efficiently and accurately. The existing systems require support to ensure processes are really carried out properly.

The company has a Very High risk rating because of the numerous issues and gaps in the design controls and operational controls. Weak password policy, unsupported backup failures, untested disaster recovery plan exposes the company to failure on critical operations from cyberattacks. For their data privacy, personal information retention policy is not followed, email encryption is not required, and offboarding is manual. These practices contributed to making their risk rating very high. The risk of unauthorized access through weak passwords or unencrypted emails, and human errors from manual processes becomes highly likely. These problems affect the confidentiality, integrity, and availability of information, and they also place the company at risk of privacy non-compliance.

The IT audit also found medium-risk controls that might not cause immediate business failure but could create long-term problems. Short network retention logs limit the company’s ability to conduct investigations more thoroughly using this evidence. The absence of policy for documentation of drive disposal should be concerning since it involves handling of sensitive data. The data sharing agreement needs to be updated to address the 4 year gap. Breach-notification procedures need stronger preparation to ensure the company can respond quickly and accurately during an actual incident.

For corrective actions, NagaTech would benefit from automating key processes, especially offboarding and data retention since their systems primarily focus on HR and payroll. Enforcing stronger authentication requirements; updating policies that no longer

IT AUDIT PROJECT: “Cybersecurity & Data Privacy Compliance Audit”

reflect current practices; and improving monitoring activities so issues can be caught early. Strengthening documentation and evidence tracking will also support compliance and improve coordination between teams.